PQC DAILY STUDY SERIES

Mergulho Profundo: Entendendo o SLH-DSA (SPHINCS+)

Day 41 | Category: Conceitos Fundamentais de PQC Date: 2026-10-26 | DAILY MONITORING

Mergulho Profundo: Entendendo o SLH-DSA (SPHINCS+)

Após nossos mergulhos profundos nos algoritmos CRYSTALS baseados em reticulados (Kyber e Dilithium), hoje exploramos o terceiro padrão PQC primário do NIST: **SLH-DSA (SPHINCS+)**. Diferente de suas contrapartes baseadas em reticulado, o SLH-DSA é um esquema de assinatura stateless (sem estado) baseado em hash. Essa diferença fundamental confere a ele um perfil de segurança único, tornando-o um componente crucial no portfólio de criptografia pós-quântica.

> **O que é uma Assinatura Baseada em Hash?**
> Um esquema de assinatura baseado em hash constrói sua segurança inteiramente na resistência à colisão de uma função de hash criptográfica subjacente (como SHA-256 ou SHAKE256). Sua segurança não se baseia em problemas da teoria dos números, como fatoração ou logaritmos discretos, que são vulneráveis ao algoritmo de Shor. Isso os torna inerentemente resistentes a ataques quânticos. O SPHINCS+ é considerado um dos algoritmos pós-quânticos mais conservadores e bem compreendidos.

Como o SLH-DSA (SPHINCS+) Funciona

O SPHINCS+ utiliza uma estrutura inteligente de múltiplas camadas de árvores. Uma mensagem é assinada usando uma chave de assinatura "de uso único" (uma Winternitz One-Time Signature, ou WOTS+). A chave pública correspondente a essa chave de uso único é então assinada por uma chave de uma estrutura de árvore de nível superior (uma hipertree). Esse processo continua subindo pelas camadas da hipertree até que a chave pública final na raiz seja usada. Essa estrutura hierárquica permite que o esquema assine múltiplas mensagens, superando a limitação de "uso único" das assinaturas básicas baseadas em hash.

- **Natureza Stateless:** As primeiras assinaturas baseadas em hash eram "stateful", o que significava que o signatário precisava rastrear quais chaves de uso único já haviam sido usadas. A reutilização de uma chave seria catastrófica para a segurança. O design "stateless" (sem estado) do SLH-DSA resolve isso brilhantemente, usando um processo determinístico e pseudo-aleatório para selecionar uma nova chave de uso único para cada assinatura,

derivada da chave secreta e da própria mensagem. Isso o torna prático para implantações no mundo real, onde o gerenciamento de estado é complexo e propenso a erros.

- **Perfil de Segurança:** A segurança do SLH-DSA está diretamente ligada à segurança da função de hash subjacente. Contanto que a função de hash seja resistente a colisões e pseudo-aleatória, o esquema de assinatura é seguro. Isso fornece uma garantia muito forte, pois não depende de suposições matemáticas novas.

Aplicabilidade a Protocolos de Internet e Cibersegurança

Enquanto o ML-DSA deve ser a escolha principal para a maioria das aplicações de assinatura digital de propósito geral devido aos seus tamanhos de assinatura menores e desempenho mais rápido, o SLH-DSA desempenha um papel crítico em contextos de alta garantia e segurança de longo prazo.

Comparação de Algoritmos: ML-DSA vs. SLH-DSA

Métrica	ML-DSA (Dilithium)	SLH-DSA (SPHINCS+)
Problema Subjacente	Module Learning with Errors (M-LWE)	Segurança de uma função de hash criptográfica
Tamanho da Assinatura	Relativamente Pequeno (~2.4 KB para Dilithium2)	Muito Grande (~8 KB para SPHINCS+-128f)
Velocidade de Assinatura	Rápida	Lenta
Velocidade de Verificação	Rápida	Muito Rápida
Suposição de Segurança	Problema de reticulado novo, mas bem estudado	Propriedades de hash conservadoras e bem compreendidas
Melhor Caso de Uso	Propósito geral: TLS, assinatura de código, certificados	Sistemas de alta garantia: assinatura de firmware, arquivos de longo prazo, CAs raiz

Seu grande tamanho de assinatura o torna menos adequado para protocolos com restrição de largura de banda, como TLS ou comunicação IoT. No entanto, suas garantias de segurança conservadoras o tornam um excelente candidato para:

- **Assinatura de Firmware:** Garantir a integridade do firmware de dispositivos, onde as atualizações são infrequentes e a segurança deve ser absoluta. A baixa velocidade de assinatura é aceitável, e a verificação rápida é uma vantagem durante o boot.

- **Chaves de Autoridade Certificadora (CA) Raiz:** As chaves raiz de uma PKI são usadas raramente, mas devem ser protegidas por décadas. A segurança robusta do SLH-DSA é ideal para este cenário.
- **Arquivamento de Documentos de Longo Prazo:** Para documentos legais ou históricos que precisam ser verificáveis por mais de 50 anos, o SLH-DSA oferece a maior confiança contra futuras quebras criptográficas.

Auto-avaliação

1. Qual é a principal vantagem de um esquema de assinatura baseado em hash como o SLH-DSA em comparação com um esquema baseado em reticulado como o ML-DSA?
2. Por que a natureza "stateless" (sem estado) do SLH-DSA é uma característica crítica para a implantação prática?
3. Dadas as suas características de desempenho (assinaturas grandes, assinatura lenta), qual das seguintes aplicações é a MENOS provável para o SLH-DSA: assinar cada handshake TLS, assinar uma atualização de firmware ou assinar um certificado de CA raiz?
